

Appendix G Reviewer Materials

G.1 Scope

This appendix item contains all correspondence planned for three human reviewers.

G.2 Participant Information Sheet

The researcher's name, student number, university email address and the supervisor's name appeared in full in the version issued to participants. They are removed here because the report is marked anonymously.

=====

Royal Holloway, University of London - Information Security Group

Study title: Evaluating the Effectiveness of Large Language Models in Generating and Auditing PCI DSS-Aligned Information Security Policies

Researcher: MSc Information Security candidate, Information Security Group

Supervisor: name removed for anonymous marking

Department: Information Security Group (ISG), Royal Holloway, University of London

Contact: university email address removed for anonymous marking

You are being invited to take part in a research study. Before you decide, it is important that you understand why the research is being carried out and what it would involve for you. Please take a few minutes to read the information below, and do ask if anything is unclear.

What is the study about?

The study looks at how well large language models, such as ChatGPT and Grok, generate and audit information security policies aligned to the Payment Card Industry Data Security Standard (PCI DSS v4.0.1). The models produce policies for

a fictitious UK organisation operating at PCI DSS Level 3, which takes card payments through a third-party payment service provider, and then audit and refine each other's work. Your role, as an experienced practitioner, is to review a small set of these policies and give your professional judgement on their quality and compliance.

Why have I been invited?

You have been approached because you have direct experience of PCI DSS, ideally as a Qualified Security Assessor or an equivalent security professional. Between one and three reviewers are being invited in total. Your expertise offers a benchmark against which the models' own assessments can be compared.

Do I have to take part?

No. Taking part is entirely voluntary. If you agree, you will be asked to sign a consent form, but you remain free to withdraw at any point up to the anonymisation of the data, without giving a reason and without any consequence. Because responses are anonymised shortly after collection, it may not be possible to remove your contribution once that step has taken place.

What will taking part involve?

- You will be sent a short scenario describing the fictitious organisation, a small number of AI-generated PCI DSS policies, the requirement text they address, and a structured scoring rubric.
- You will review the policies against the rubric and note where they meet or fall short of the PCI DSS requirements, flag anything that looks compliant on the surface but would not survive a real assessment, and comment on whether the policies could be put to work in a firm of this kind.
- This is expected to take around 60 to 90 minutes, at a time that suits you. It can be done remotely, in your own time.

What information will be collected?

Apart from your name and email address, which are needed to obtain your consent and to send you the review materials, no personal or sensitive information is gathered, and no information about your employer or clients is sought. Alongside

your professional assessments and comments on the policies, a general indication of your background is recorded, for example years of experience or certification type.

Your name and contact details are held separately from your review responses, which are labelled with a generic identifier such as "Reviewer A". The record linking the two is destroyed once responses have been anonymised, shortly after collection. Consent is the lawful basis for holding this information under the UK General Data Protection Regulation.

No cardholder data or proprietary organisational information is involved at any stage, since every policy relates to a made-up company.

Will my taking part be kept confidential?

Yes. You will not be identified by name, employer or job title in the dissertation or in any output from it. Responses are anonymised and reported in aggregate or with generic labels such as "Reviewer A". Data is stored securely on password-protected Royal Holloway systems and is accessible only to the researcher and, where needed, the supervisor. The research is conducted in line with the UK General Data Protection Regulation and the Data Protection Act 2018. Royal Holloway is the data controller for this study.

What are the risks and benefits?

There are no anticipated risks to you beyond the time involved. There is no direct benefit to you, although your input contributes to a better understanding of where AI-generated security policies can and cannot be trusted, which is of practical interest to the compliance community.

What happens to the results?

The results form part of an MSc dissertation submitted to Royal Holloway. Anonymised findings may also be used in related academic outputs. Raw data is retained securely for the period required by the College's research data policy and then deleted. If you would like one, a short summary of the anonymised findings can be sent to you once the dissertation has been submitted.

Who has reviewed this study?

This study has been reviewed and approved by the ISG Ethics Panel at Royal Holloway, University of London.

What if I have a concern?

If you have any questions, please contact the researcher or the supervisor using the details above. If you wish to raise a concern independently, you may contact the Chair of the ISG Ethics Panel, or the College Data Protection Officer at dataprotection@rhul.ac.uk.

Thank you for taking the time to read this information.

G.3 Consent Form

The researcher's name, student number, university email address and the supervisor's name appeared in full in the version issued to participants. They are removed here because the report is marked anonymously.

Royal Holloway, University of London [Information Security Group]

Study title: Evaluating the Effectiveness of Large Language Models in Generating and Auditing PCI DSS-Aligned Information Security Policies

Researcher: MSc Information Security candidate, Information Security Group

Supervisor: name removed for anonymous marking

Please initial each box to confirm your agreement.

Statement	Initials
1. I confirm that I have read and understood the Participant Information Sheet for the above study, and have had the opportunity to ask questions.	
2. I understand that my participation is voluntary and that I am free to withdraw at any time, up to the point at which the data is anonymised, without giving a reason and without any consequence.	
3. I understand that, apart from my name and contact details held for consent and correspondence, no sensitive information about me, my employer or my clients will be collected, and that my identity will not be revealed in any output from the study.	
4. I understand that my name and contact details are held separately from my responses, and that the record linking the two is destroyed once my responses have been anonymised.	
5. I understand that my responses will be anonymised, stored securely, and handled in line with UK GDPR and the Data Protection Act 2018, with Royal Holloway as the data controller.	
6. I understand that the anonymised findings will be used in an MSc dissertation and may be	

Statement	Initials
used in related academic outputs.	
7. I agree to take part in the study described above.	

Name of participant: _____ Date: _____

Signature: _____

Name of researcher: removed for anonymous marking Date: _____

Signature: _____

One copy for the participant, one copy retained by the researcher.

G.4 Correspondence as issued

G.4.1 Invitation email, sent with the Participant Information Sheet attached

Subject: Request for expert review, MSc research on AI-generated PCI DSS policies

Dear [Name],

I am an MSc Information Security student at Royal Holloway, University of London, working on a dissertation about whether large language models can produce information security policies that actually meet PCI DSS v4.0.1. I am writing to ask whether you would be willing to act as an expert reviewer.

The study asks two models, ChatGPT and Grok, to write PCI DSS-aligned policies for a fictitious UK e-commerce merchant validating at Level 3 under SAQ A-EP, and then has each model audit the other's work. What the models cannot tell me is whether their output would survive contact with a real assessment. That is where an experienced practitioner's judgement is needed, and why I am approaching you.

Taking part would involve reading a few pages describing the fictitious organisation, then reviewing a small set of AI-generated policies covering PCI DSS Requirements 7, 8, 10 and 12, scoring them against a structured rubric, and noting where they fall short. I would expect it to take around 60 to 90 minutes, done remotely and at whatever time suits you. There is no payment, and participation is entirely voluntary.

I have attached the Participant Information Sheet, which sets out what is involved, what data is held and how it is handled. The study has been reviewed and approved by the ISG Ethics Panel. You will not be identified by name, employer or job title in the dissertation or in anything that follows from it.

Please do take a week or so to consider it, and ask me anything at all in the meantime. If you are willing to take part, I will send a short consent form, and the review materials once that is returned.

I know this is a real ask on your time, and I would be very grateful for it either way.

With best wishes,

[Researcher's name, university email address and supervisor's name removed for anonymous marking]

Attachment: Participant Information Sheet

G.4.2 Reminder email, sent once only

Subject: Re: Request for expert review, MSc research on AI-generated PCI DSS policies

Dear [Name],

I wrote a couple of weeks ago about acting as an expert reviewer for my MSc dissertation on AI-generated PCI DSS policies. I know how busy this time of year is, so this is just a brief note in case the message was buried.

If you would rather not take part, please do say, or simply ignore this; I will not write again either way, and there is no obligation at all.

With best wishes,

[Researcher's name removed for anonymous marking]

G.4.3 Covering note, sent with the review pack

Dear [Name],

Thank you for agreeing to take part, and for returning the consent form. Everything you need is attached.

What is enclosed

Scenario brief. A description of NorthPay Ltd, the fictitious UK e-commerce merchant the policies were written for. It runs to a few pages and covers the technical estate, the way the organisation is governed and the legal obligations it carries alongside PCI DSS. Please read it first. The policies are meant to be proportionate to a firm of this size and shape, so the scenario matters a good deal to the judgement.

The brief describes the organisation as it currently stands. It does not say anything about whether that state meets the standard, and it does not quote requirement text; that is the question the policies are supposed to answer and the one I am asking you to judge.

Policies for review. Four AI-generated information security policies covering PCI DSS v4.0.1 Requirements 7, 8, 10 and 12, labelled only by code: P1a, P1b, P2a and P2b. Which model wrote which is deliberately not disclosed, so that your assessment is not influenced by any view you may hold about a particular tool. Please take P1b and P2b first, then P1a and P2a; if time runs short, a completed pair is more useful to me than four partial ones.

Requirement text. The relevant text of Requirements 7, 8, 10 and 12 from PCI DSS v4.0.1, for reference.

Scoring rubric and response form. The Evaluation Rubric and Scoring Guide at Appendix D, which explains how a policy is scored, and a Reviewer Response Capture Form for each policy, already labelled with its code. Your reviewer identifier is written at the top of each form; please do not add your name to any sheet.

What I am asking you to do

Score each policy on the four rubric criteria, one requirement area at a time, and add whatever comments you think matter. Before scoring a live policy, please score the two worked examples in the rubric, Sections D.8 and D.9, on the calibration table at the front of the form; this is how I check that the rubric reads the same way to everyone. Three things in particular would be valuable:

- Anything that reads as compliant on the surface but would not survive a real assessment.
- Any requirement or sub-requirement that has been missed, misstated or invented.
- Whether an organisation of this size could realistically adopt and enforce the policy as written.

Please answer only from the material enclosed. There is no need to reference any real assessment, client or employer, and I would ask you not to.

Returning your review

Please send the completed form back by [date, roughly two weeks from sending]. If that is difficult, do tell me; a partial review of one or two requirement areas is still genuinely useful.

If anything is unclear, or if you would like to talk it through rather than write it down, I am happy to arrange a short call.

With thanks,

[Researcher's name removed for anonymous marking]

G.4.4 Note sent after the responses were received

Dear [Name],

Thank you, this is exactly the kind of judgement the study needed, and I am grateful for the time it took.

Your responses will be anonymised shortly and reported under a generic label only. Once the dissertation is submitted, I would be glad to send you a short summary of the anonymised findings if that would be of interest.

With thanks again,

[Researcher's name removed for anonymous marking]